

ACTIVIDAD 04

Una página demasiado convincente

Simulación controlada con SET Credential Harvester

REPORTE TÉCNICO · EVIDENCIA ACADÉMICA

JUAN FRANCISCO ORTEGA JIMÉNEZ

Matrícula 184918 · Séptimo semestre

ASIGNATURA	CNO IV – Seguridad Informática / Fundamentos de Ciberseguridad
------------	--

DOCENTE	Mtro. Servando López Contreras
---------	--------------------------------

ENTORNO	Kali Linux en VirtualBox · laboratorio local 127.0.0.1
---------	--

FECHA	30 de agosto de 2026
-------	----------------------

ORGANIZACIÓN DEL INFORME

Tabla de contenido

La estructura sigue los apartados solicitados en la consigna y añade un resumen ejecutivo, el análisis explícito de la rúbrica y una bitácora visual con todas las capturas proporcionadas.

Resumen ejecutivo	3
1. Objetivo de la actividad	4
2. Descripción del escenario	5
3. Configuración del laboratorio	6
4. Credential Harvester	7
5. Evidencias y descripción	8
6. Flujo de captura	23
7. Indicadores de phishing	25
8. Controles de seguridad	26
9. Resultados y rúbrica	27
10. Conclusiones	28
11. Referencias	29
Apéndice A. Consigna y rúbrica	30

NOTA ÉTICA El reporte documenta exclusivamente una simulación autorizada y local. No se incluyen servidores funcionales, portales reales, credenciales personales, dominios externos, suplantación DNS, payloads ni código malicioso.

SÍNTESIS

Resumen ejecutivo

Este informe documenta una simulación académica de ingeniería social realizada con Social-Engineer Toolkit (SET) y su módulo Credential Harvester. Se diseñó un portal ficticio llamado Nexo Campus y se publicó únicamente en 127.0.0.1, dentro de una máquina virtual Kali Linux. El formulario recibió datos de prueba, generó una petición HTTP POST y permitió observar cómo el servidor identifica, muestra y registra los parámetros enviados.

El resultado principal fue satisfactorio: el portal se cargó de forma local, Firefox registró un POST con respuesta 200, SET mostró la recepción de los campos escenario, username y password, y la evidencia persistió en harvester.log y en un reporte XML después de finalizar la ejecución. Al concluir, el puerto 80 quedó sin proceso escuchando y HARVESTER_LOG_PASSWORDS se restauró a OFF.

RESULTADO La práctica cumple los cinco criterios de nivel excelente: configuración funcional, evidencia ordenada, análisis técnico del POST, identificación de indicadores y controles, y reporte con diagrama y conclusión.

Dato	Valor verificado
Portal	Nexo Campus (identidad completamente ficticia)
Dirección	http://127.0.0.1/
Módulo	SET · Credential Harvester · Custom Import
Petición	POST / · HTTP 200 · application/x-www-form-urlencoded
Datos de prueba	ACT04_LOCAL · alumno_prueba04 · Solo-Lab-2026!
Persistencia	harvester.log + reporte XML
Cierre	Puerto 80 sin listener + registro de contraseñas en OFF

01 · OBJETIVO

1. Objetivo de la actividad

1.1 Objetivo general

Implementar y analizar, dentro de un entorno de laboratorio controlado, una simulación de ingeniería social mediante Social-Engineer Toolkit (SET) y una página web ficticia, con el fin de comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

1.2 Objetivos específicos

- Configurar un escenario básico de ingeniería social con SET y el módulo Credential Harvester.
- Implementar un portal web ficticio con nombre de sistema, usuario, contraseña, botón de acceso y aviso de sesión expirada.
- Observar el recorrido técnico de los datos desde el formulario hasta la solicitud HTTP POST y los registros de SET.
- Diferenciar entre la captura de valores enviados por una persona y el cracking de una contraseña cifrada o resumida.
- Identificar indicadores técnicos y visuales de una página potencialmente fraudulenta.
- Proponer controles preventivos, detectivos y de respuesta, indicando su alcance y sus limitaciones.
- Conservar evidencia ordenada de la ejecución y restablecer el laboratorio a una condición segura al terminar.

PREGUNTA GUÍA ¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing? La respuesta técnica se desarrolla en el apartado 4 y se demuestra con las Figuras 17 a 24.

02 · ESCENARIO

2. Descripción del escenario

El caso plantea que el área de seguridad de una organización recibe reportes de empleados que han visto un mensaje relacionado con una supuesta actualización de credenciales. El vínculo conduce a un portal aparentemente institucional que solicita iniciar sesión de nuevo porque la sesión ha expirado. Aunque su apariencia puede resultar común, la página no pertenece a la organización (López Contreras, 2026).

Para representar ese escenario sin involucrar instituciones reales, se creó Nexo Campus. El portal incorpora los elementos solicitados: nombre del sistema, campo de usuario, campo de contraseña, botón de ingreso y mensaje de expiración. También incluye advertencias visibles de uso local para evitar que la demostración se confunda con un servicio auténtico.

2.1 Alcance autorizado

Dentro del alcance	Fuera del alcance
Kali Linux en VirtualBox y navegador Firefox.	Sistemas, cuentas o redes de terceras personas.
Dirección de loopback 127.0.0.1.	Publicación del servidor hacia Internet.
Identidad ficticia Nexo Campus.	Clonación de portales, marcas o empresas reales.
Credenciales de laboratorio creadas para la prueba.	Credenciales personales, académicas o laborales.
Formulario HTML y petición POST local.	Dominios externos, DNS spoofing, payloads o malware.
Logs y XML conservados como evidencia privada.	Distribución de datos capturados o del servidor funcional.

LÍMITE ÉTICO La finalidad fue observar y documentar el mecanismo técnico. En ningún momento se solicitó información a personas ajenas al laboratorio ni se intentó hacer accesible el portal fuera de localhost.

03 · CONFIGURACIÓN

3. Configuración del laboratorio

Componente	Configuración utilizada
Equipo anfitrión	Windows 11 con Oracle VirtualBox
Máquina virtual	Kali Linux 2026.2 (amd64)
Herramienta	Social-Engineer Toolkit; paquete observado 8.0.3+git20241021-0kali1 y pantalla de SET 8.1.3
Vector	Social-Engineering Attacks → Website Attack Vectors → Credential Harvester → Custom Import
Portal	/home/kali/actividad04_set/portal/index.html
Servidor	127.0.0.1, TCP/80, HTTP sin TLS por tratarse de loopback
SET	APACHE_SERVER=OFF · WEB_PORT=80 · WEBATTACK_SSL=OFF
Registro temporal	HARVESTER_LOG_PASSWORDS=ON solo durante la simulación; OFF al finalizar
Navegador	Firefox con Network Monitor y Persist Logs
Artefactos	harvester.log, session_set.txt y reporte XML

3.1 Comprobaciones previas y posteriores

```
sudo grep -nE '^(APACHE_SERVER|WEB_PORT|WEBATTACK_SSL|HARVESTER_LOG_PASSWORDS)='
/etc/setoolkit/set.config
sudo ss -ltnp sport = :80
```

Antes de iniciar, la consulta del puerto mostró solo el encabezado, por lo que no existía un proceso en escucha. La misma comprobación se repitió después del cierre. Finalmente se confirmó HARVESTER_LOG_PASSWORDS=OFF. Estas verificaciones reducen el riesgo de dejar un servicio o una opción de registro activos fuera del periodo autorizado.

3.2 Incidencias técnicas controladas

- La ruta inicial de set.config era incorrecta; se localizó el archivo real con find.
- SET no pudo consultar su versión por falta de resolución de nombres; el error correspondía a una solicitud externa y el laboratorio local continuó sin Internet.
- Se ingresó 127.0.0.1 donde se esperaba una ruta de archivos; se reinició SET y se indicó la carpeta correcta del portal.
- La URL se registró inicialmente con https:// aunque SSL estaba desactivado; la plantilla se ajustó a http://127.0.0.1/ antes de enviar datos.
- Dos variantes del filtro ss tuvieron sintaxis incorrecta; se corrigió con sport = :80 y se obtuvo una comprobación limpia.

04 · FUNDAMENTO CONCEPTUAL

4. Credential Harvester: concepto y función

Un Credential Harvester es un mecanismo que recibe y registra los valores enviados mediante un formulario de autenticación. En SET, el módulo forma parte de los vectores web para evaluaciones autorizadas de ingeniería social. Su función dentro de una campaña de phishing consiste en demostrar qué sucede cuando una persona confía en una página falsa e introduce datos: el navegador crea una solicitud, el servidor recibe los parámetros y la herramienta los conserva para el análisis del ejercicio.

SET es una herramienta de código abierto orientada a pruebas de penetración relacionadas con ingeniería social. TrustedSec señala que debe utilizarse únicamente con autorización y un alcance explícito; el sitio oficial de Kali la clasifica como una herramienta de social engineering y muestra su instalación y ejecución (Kali Linux, 2026; TrustedSec, 2026).

4.1 Captura no es cracking

Aspecto	Captura con Credential Harvester	Cracking de contraseña
Entrada	Valores que la persona escribe y envía.	Hash, cifrado u otra representación protegida.
Mecanismo	Recepción de parámetros HTTP por el servidor.	Búsqueda, diccionario, fuerza bruta o análisis criptográfico.
Resultado	Texto enviado por el formulario, si el registro está habilitado.	Intento de inferir o recuperar el secreto original.
En esta práctica	Sí: tres parámetros ficticios mediante POST.	No se realizó; no hubo hashes ni ataques de contraseña.
Riesgo principal	Engaño y confianza de la persona usuaria.	Debilidad del secreto, algoritmo o almacenamiento.

RESPUESTA DIRECTA Credential Harvester no “adivina” una contraseña. Recibe lo que el formulario envía. Por eso la ingeniería social y la verificación del dominio son tan importantes como la robustez técnica del sistema.

05 · BITÁCORA VISUAL

5. Evidencias y descripción del funcionamiento

Las siguientes 28 capturas documentan toda la ejecución, incluidos los intentos corregidos. Mantener las incidencias dentro de la bitácora permite demostrar diagnóstico, trazabilidad y recuperación, sin confundirlas con el resultado final. Todas las credenciales visibles fueron creadas exclusivamente para el laboratorio.

La secuencia se lee de preparación a cierre: instalación y configuración, importación del portal, captura del POST, confirmación en SET, persistencia en archivos y restauración del entorno. Las Figuras 1 a 28 son capturas propias del 30 de agosto de 2026.

BITÁCORA VISUAL · PREPARACIÓN DEL ENTORNO

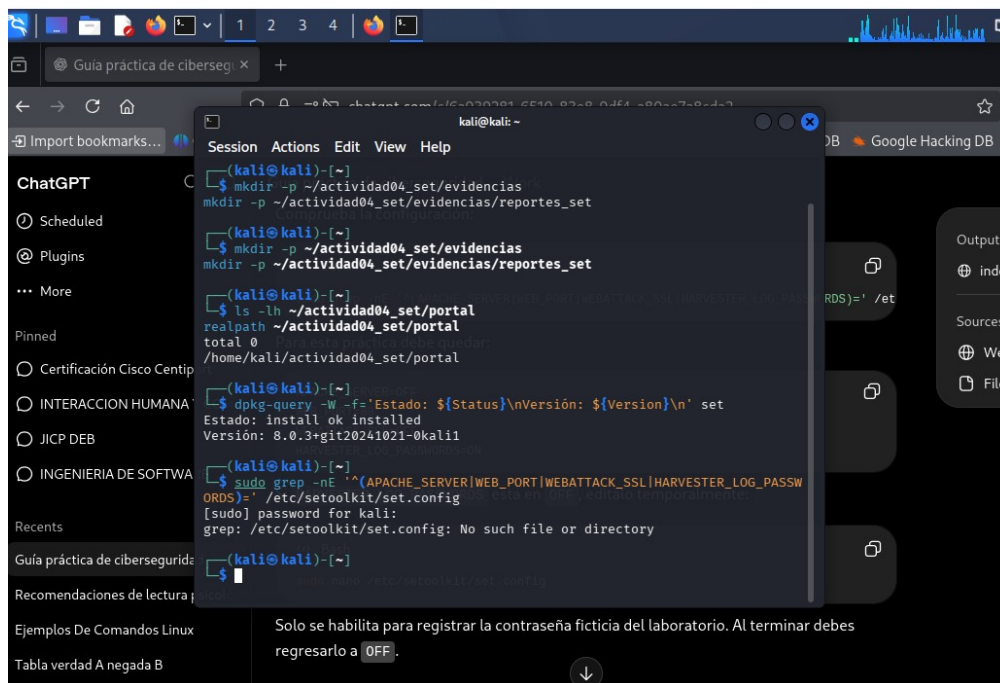


Figura 1. Creación de la estructura de evidencias y primera verificación de SET. Se crearon las carpetas del portal y de evidencias. La consulta inicial a `/etc/setoolkit/set.config` falló porque esa no era la ruta correcta en esta instalación; el hallazgo se corrigió en la siguiente comprobación.

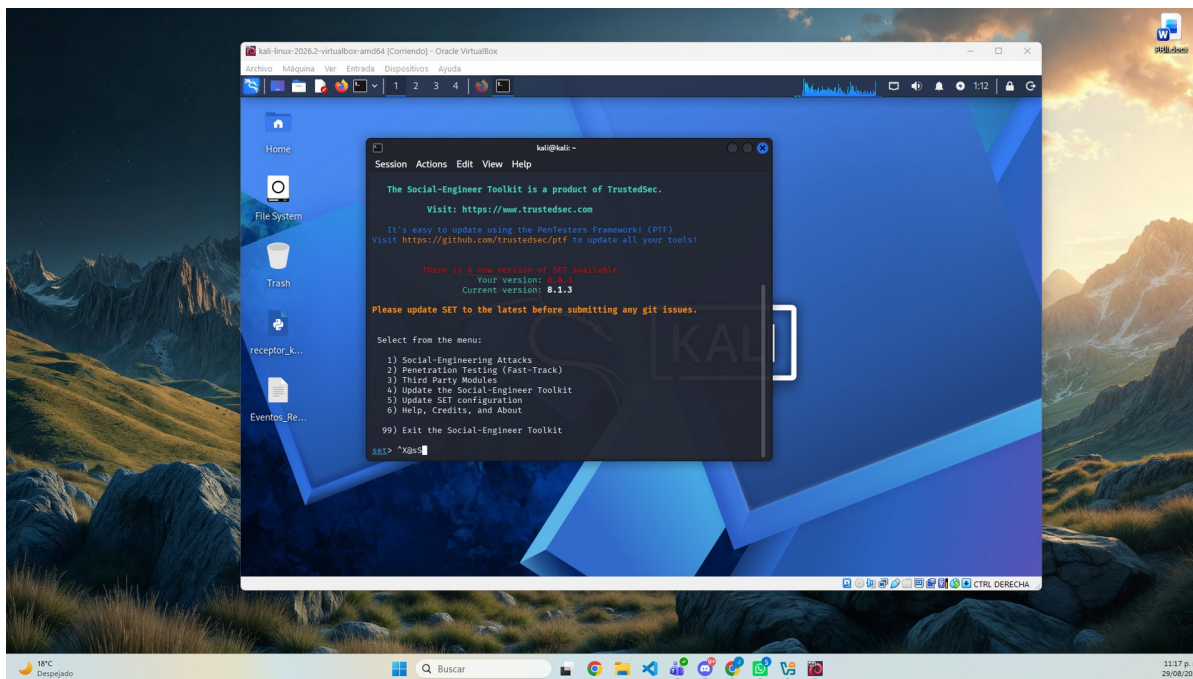


Figura 2. Inicio de Social-Engineer Toolkit. SET abrió correctamente y presentó el menú principal. La pantalla identifica la versión disponible en el entorno y confirma que la herramienta está instalada.

BITÁCORA VISUAL · PREPARACIÓN DEL ENTORNO

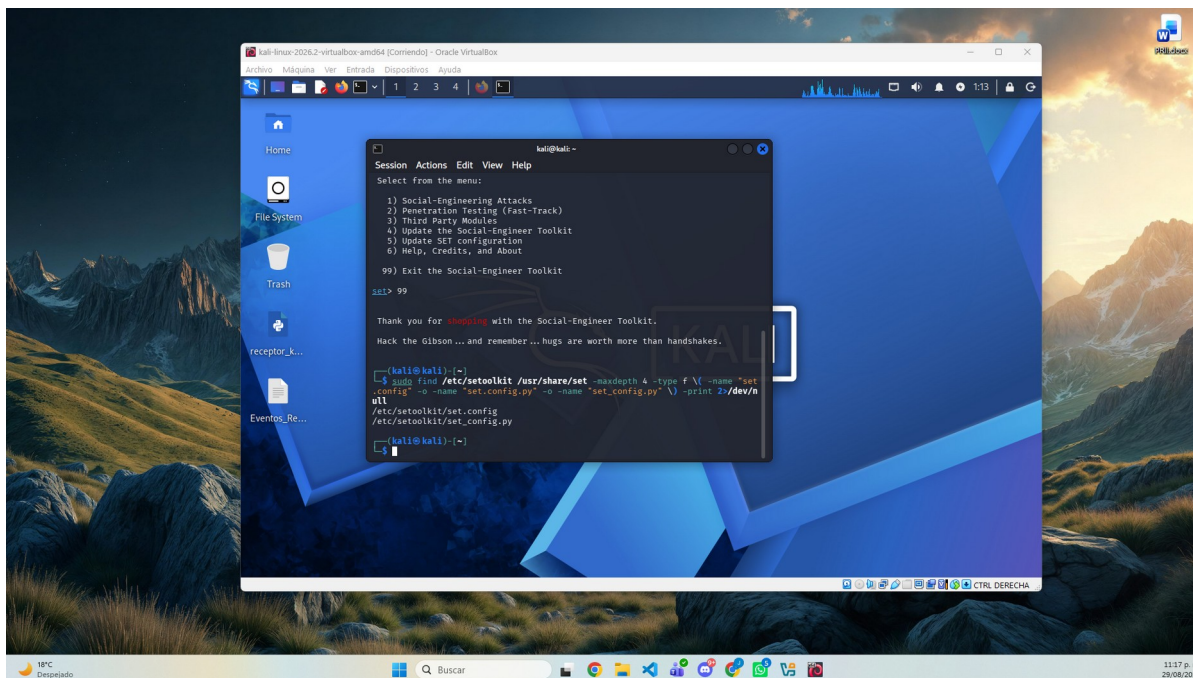


Figura 3. Localización de los archivos de configuración. La búsqueda controlada ubicó `/etc/setoolkit/set.config` y `/etc/setoolkit/set_config.py`, resolviendo el error de ruta observado al inicio.

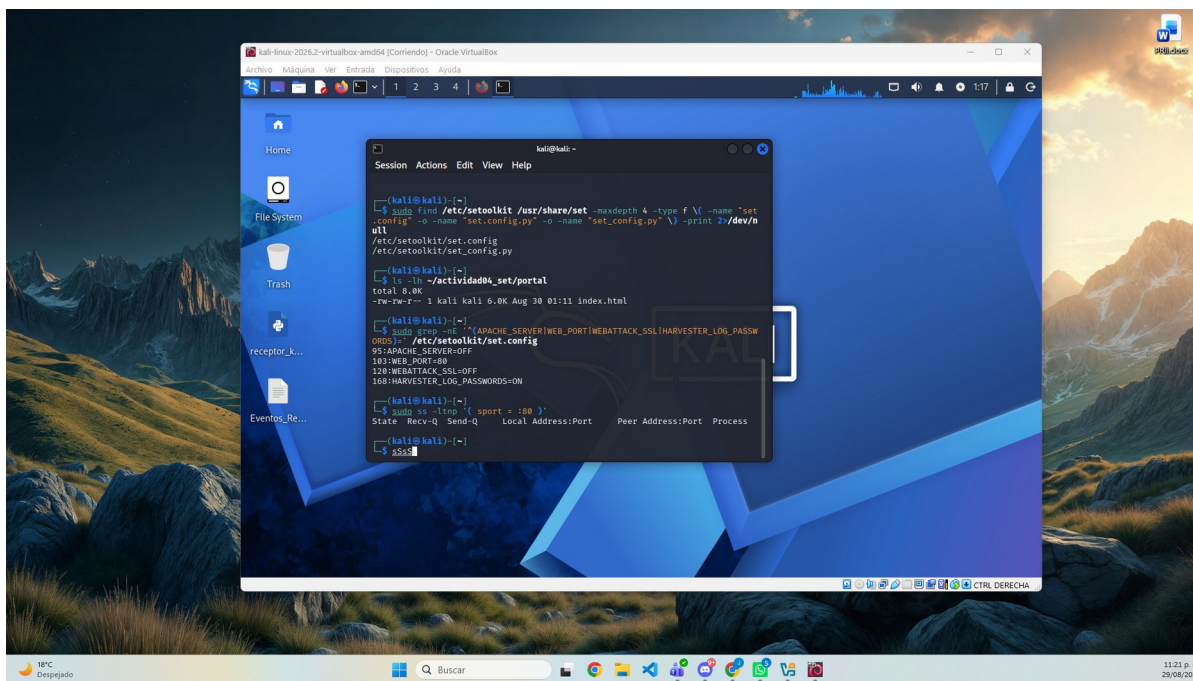


Figura 4. Validación del portal, configuración y disponibilidad del puerto 80. Se comprobó la existencia de `index.html`, `APACHE_SERVER=OFF`, `WEB_PORT=80`, `WEBATTACK_SSL=OFF` y `HARVESTER_LOG_PASSWORDS=ON`. El comando `ss` no mostró un proceso escuchando, por lo que el puerto estaba libre antes de iniciar la simulación.

BITÁCORA VISUAL · PREPARACIÓN DEL ENTORNO · INCIDENCIAS RESUELTAS

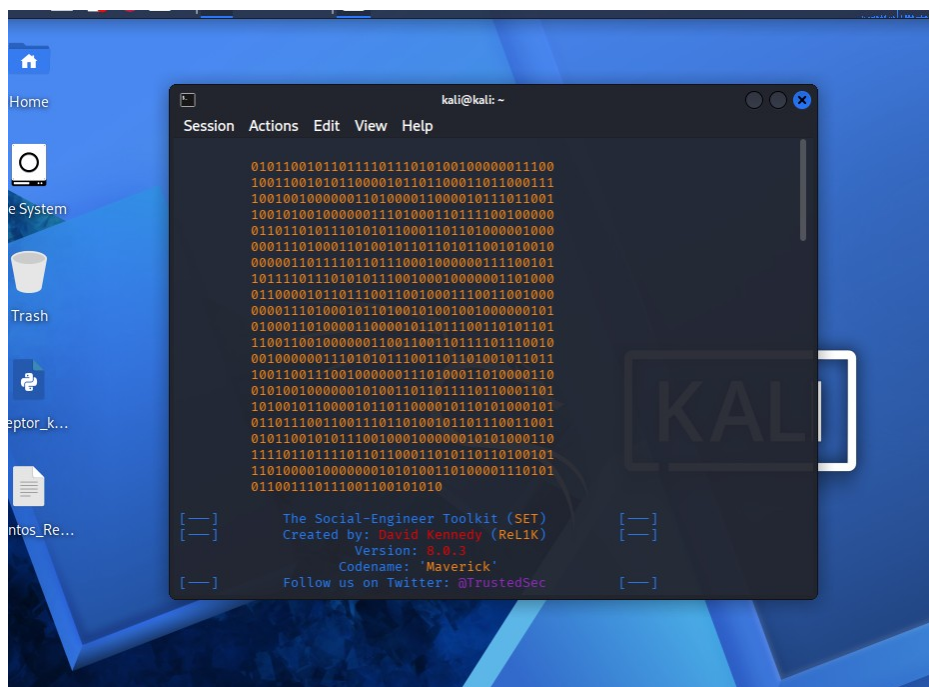


Figura 5. Segunda ejecución de SET. Se reinició SET después de las verificaciones para continuar con la configuración del vector web. La captura conserva el encabezado y la versión usada durante la práctica.

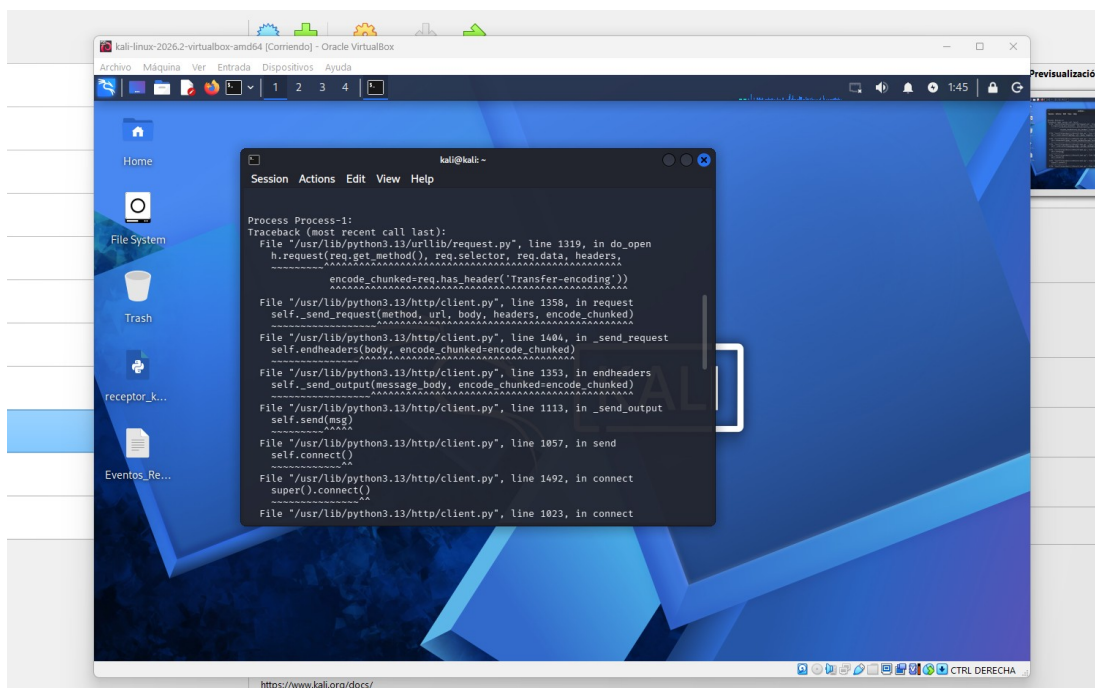


Figura 6. Trazo de error por ausencia de resolución de nombres. SET intentó consultar un recurso externo para comprobar su versión. Al no existir conectividad, Python mostró una excepción de red; el servicio local aún no se había iniciado y el error no implicó exposición del laboratorio.

BITÁCORA VISUAL · INCIDENCIAS RESUELTAS

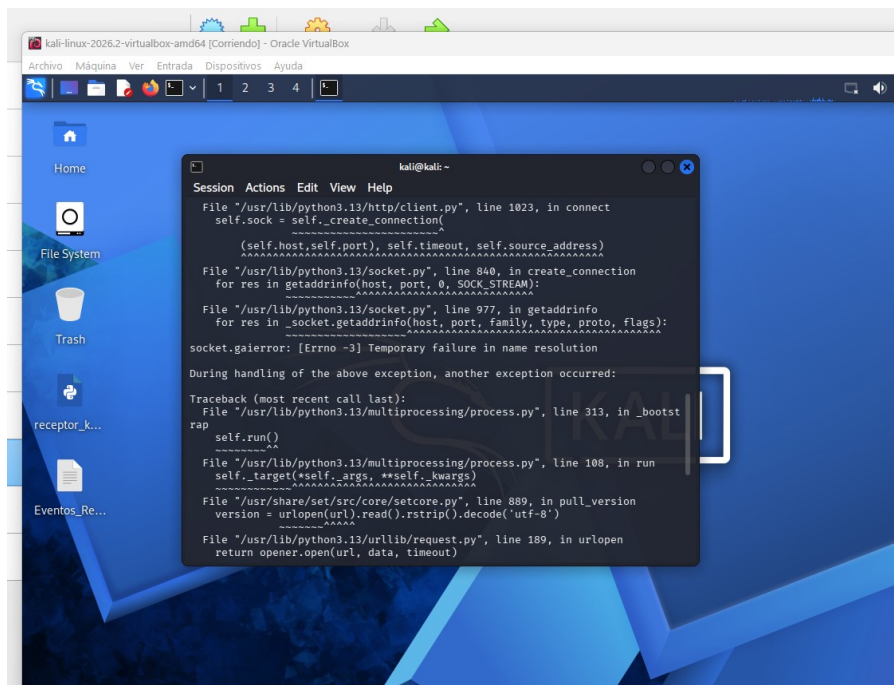


Figura 7. Identificación de la causa del error de red. La traza muestra `socket.gaierror: Temporary failure in name resolution` y la llamada `pull_version`, evidencias de que la falla pertenecía a la comprobación de actualización y no al portal de 127.0.0.1.

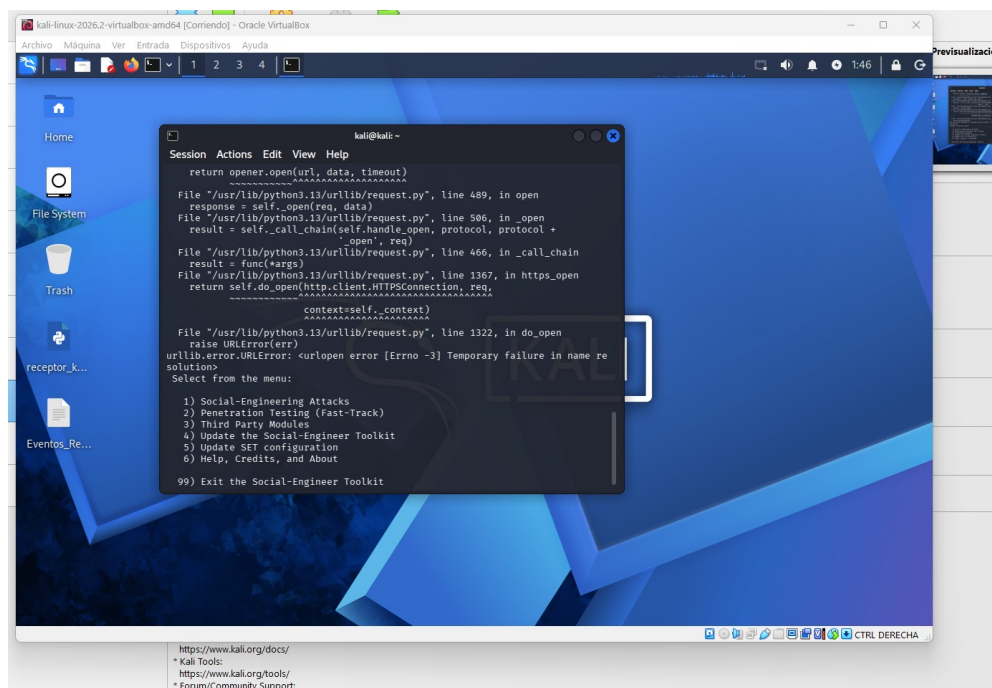


Figura 8. Recuperación del menú tras la falla externa. A pesar del error de conectividad, SET regresó al menú interactivo. La práctica pudo continuar sin Internet, condición coherente con el alcance local establecido.

BITÁCORA VISUAL · INCIDENCIAS RESUELTAS · IMPORTACIÓN DEL PORTAL FICTICIO

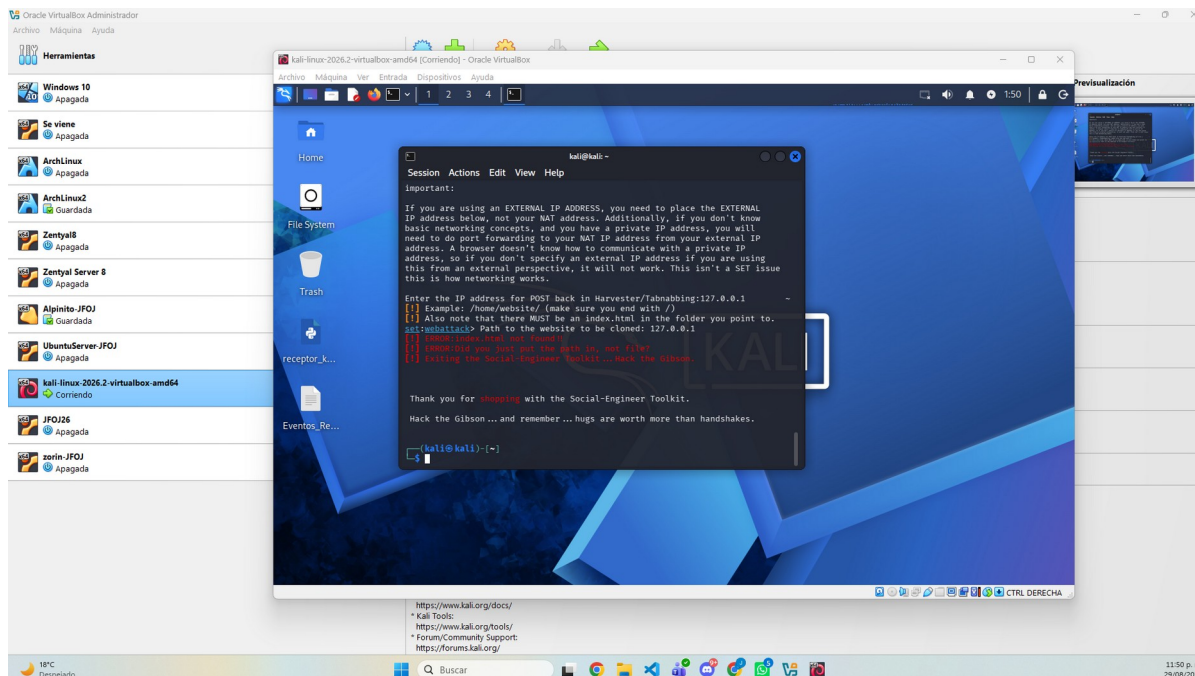


Figura 9. Corrección de una ruta ingresada como dirección IP. En el primer intento se proporcionó 127.0.0.1 donde SET esperaba la ruta local del sitio. La herramienta no encontró index.html y finalizó; no se efectuó ninguna captura de información.

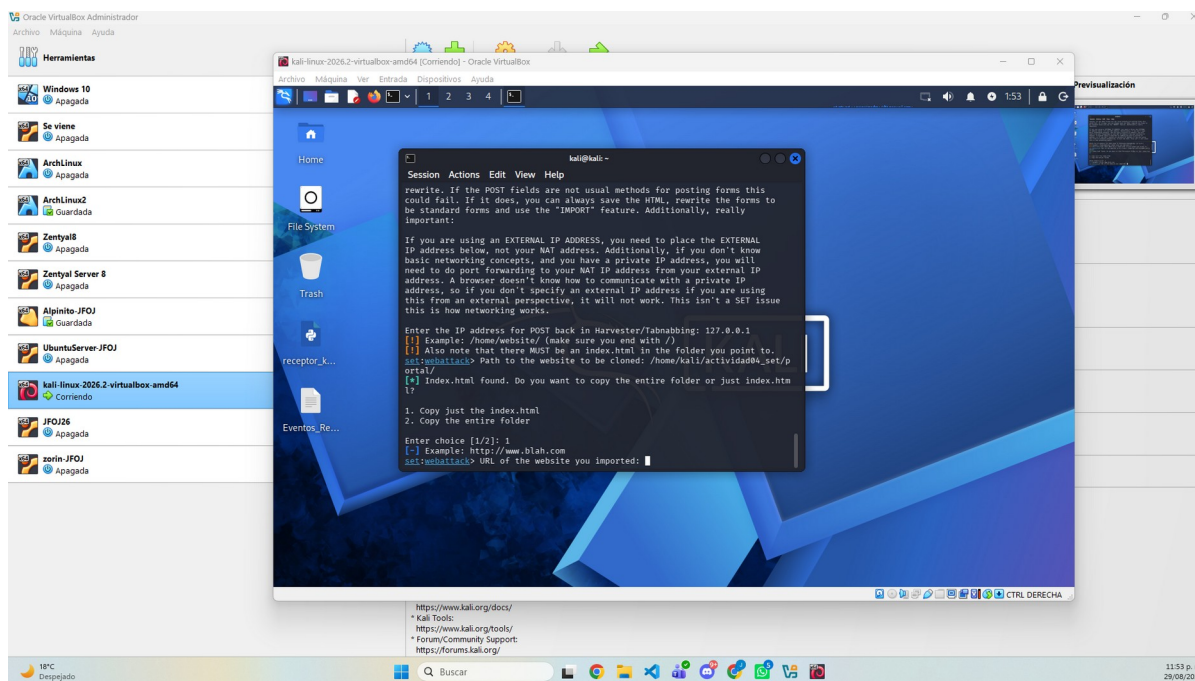


Figura 10. Importación correcta del archivo index.html. Se indicó /home/kali/actividad04_set/portal/, SET detectó index.html y se eligió copiar únicamente ese archivo, suficiente porque el portal era autocontenido.

BITÁCORA VISUAL · IMPORTACIÓN DEL PORTAL FICTICIO

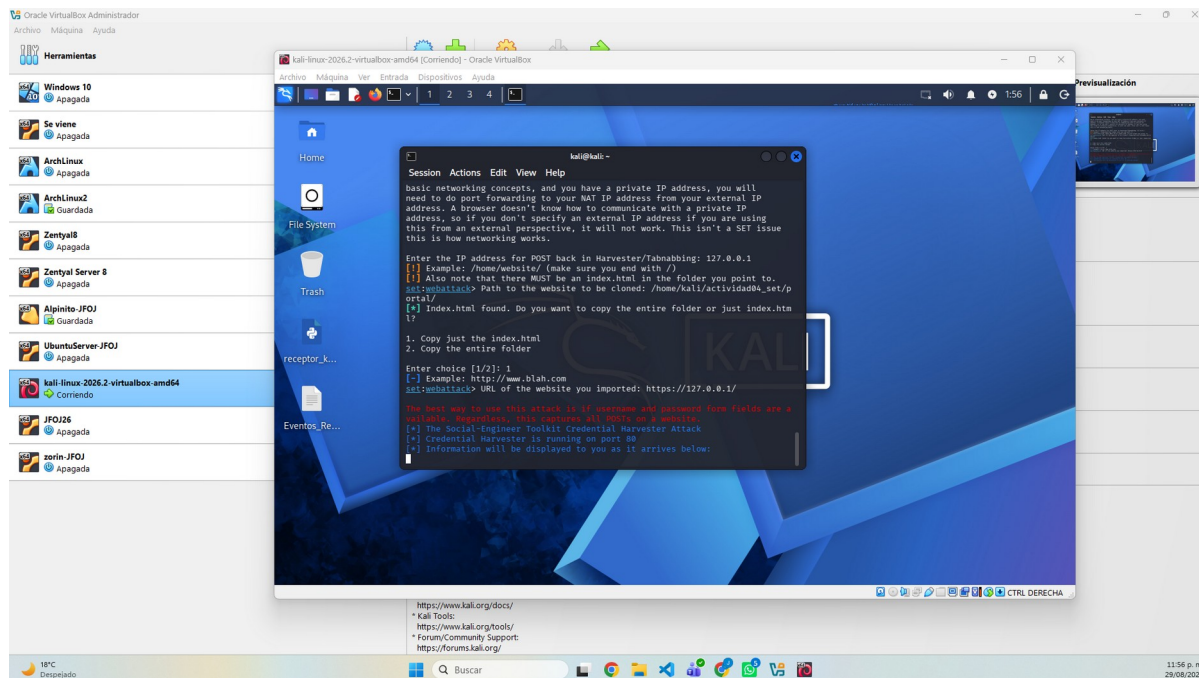


Figura 11. Primer arranque del Credential Harvester en el puerto 80. El módulo confirmó que el Credential Harvester estaba activo. La URL de retorno se ingresó inicialmente con HTTPS, aunque WEBATTACK_SSL permanecía deshabilitado; esa inconsistencia se corrigió antes de enviar datos.

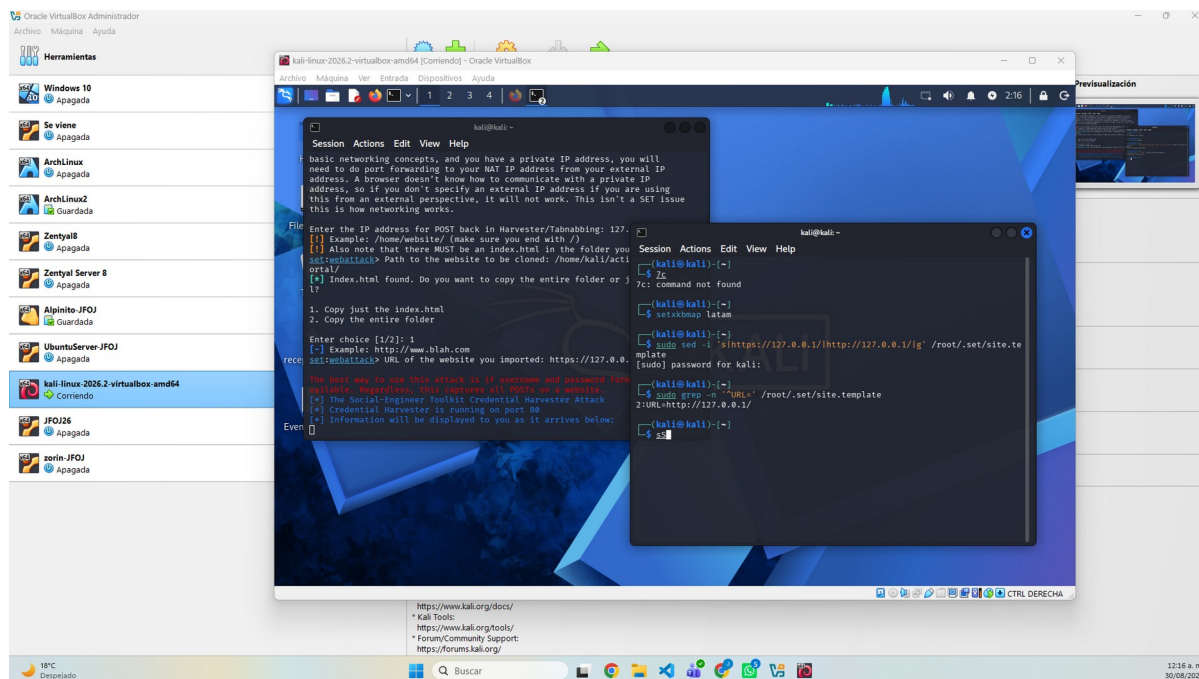


Figura 12. Ajuste del teclado y corrección del esquema HTTP. En una segunda terminal se aplicó setxkbmap latam y se sustituyó la URL de la plantilla por http://127.0.0.1/. La verificación grep confirmó el valor corregido mientras SET continuaba escuchando.

BITÁCORA VISUAL · EJECUCIÓN DE LA SIMULACIÓN

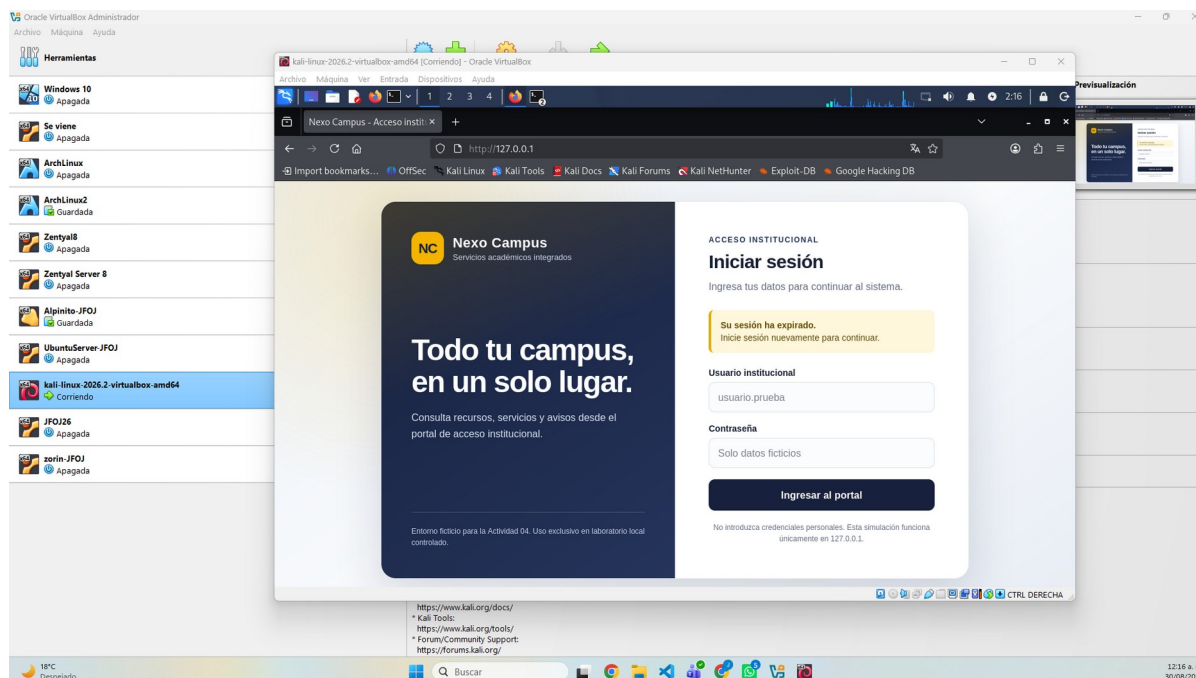


Figura 13. Portal ficticio Nexo Campus servido en localhost. Firefox mostró el sistema institucional simulado con nombre, campos de usuario y contraseña, botón de ingreso y el mensaje de sesión expirada. La barra de direcciones confirma 127.0.0.1 y el propio sitio advierte que solo admite datos ficticios.

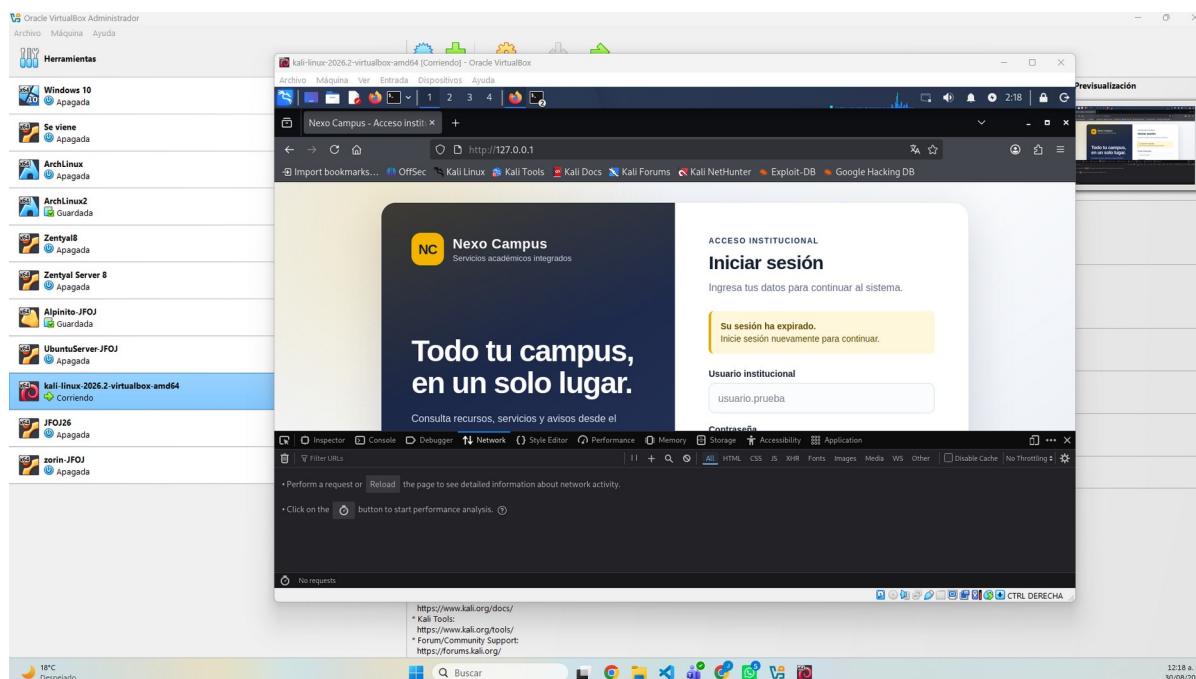


Figura 14. Preparación del monitor de red del navegador. Se abrió la pestaña Network de Firefox antes del envío. Al inicio no había solicitudes, lo que permite atribuir la petición posterior a la interacción controlada con el formulario.

BITÁCORA VISUAL · EJECUCIÓN DE LA SIMULACIÓN

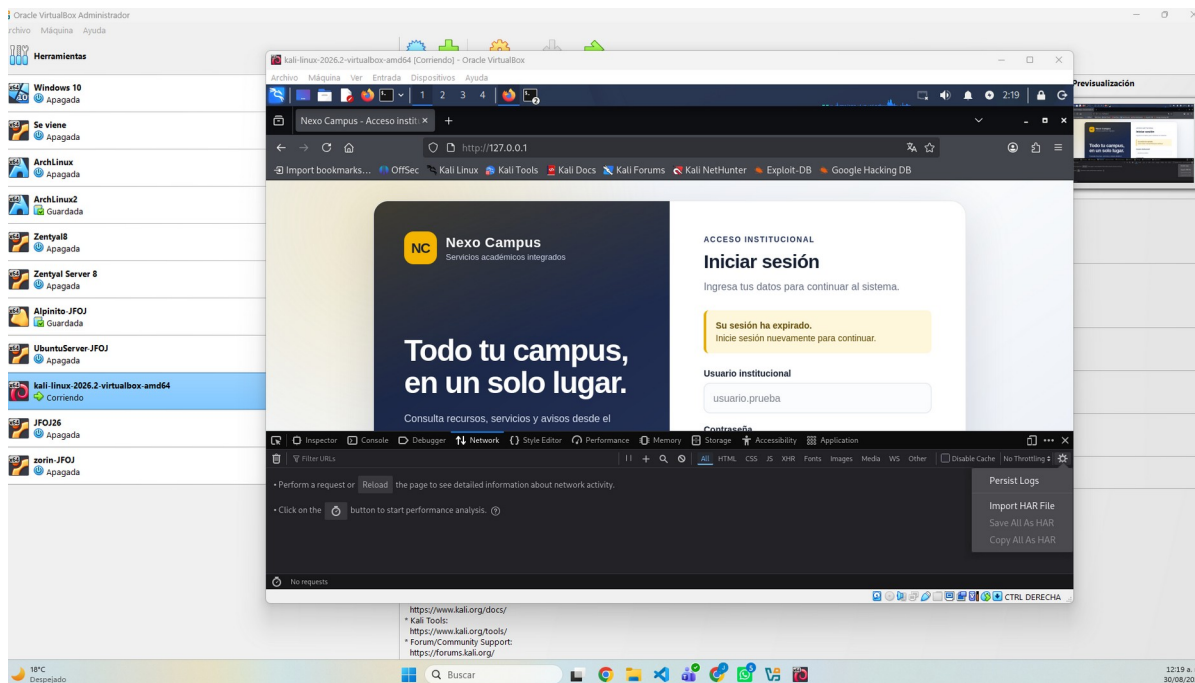


Figura 15. Apertura de las opciones del monitor de red. La captura muestra la opción Persist Logs antes de habilitarla; conservar las solicitudes facilita documentar la navegación posterior a un envío de formulario.

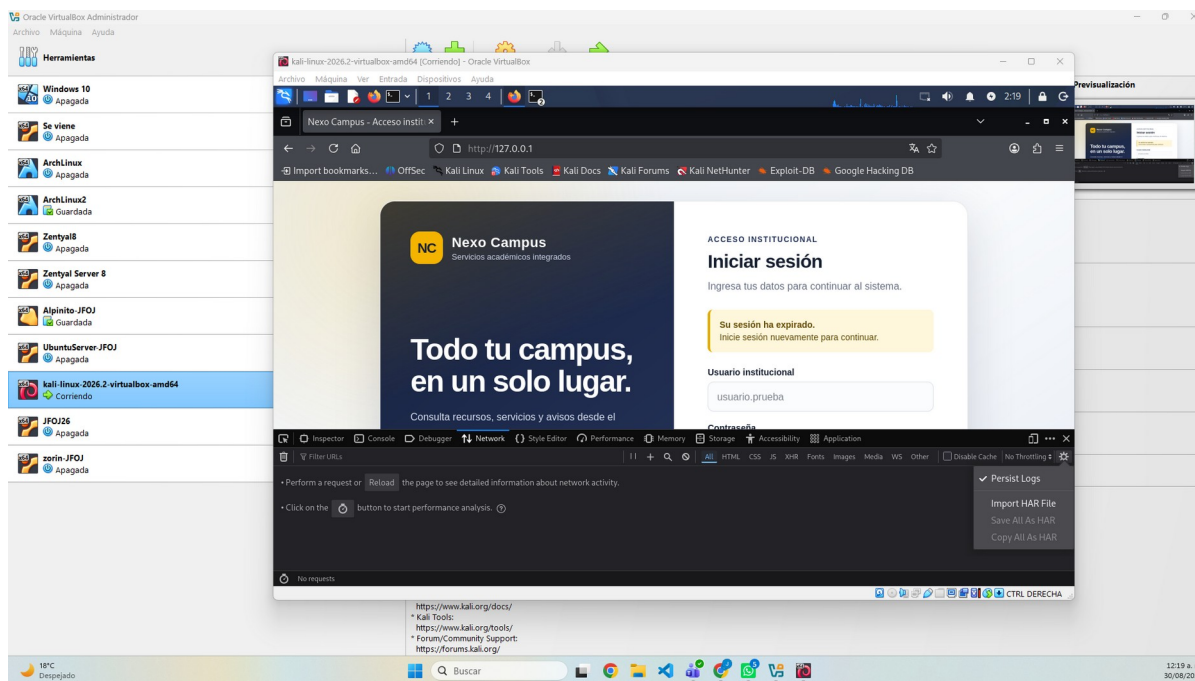


Figura 16. Persistencia de solicitudes habilitada en Firefox. Persist Logs quedó activado. Con ello, el registro de la petición POST se mantendría visible aunque el navegador cargara una nueva respuesta.

BITÁCORA VISUAL · CAPTURA Y ANÁLISIS TÉCNICO

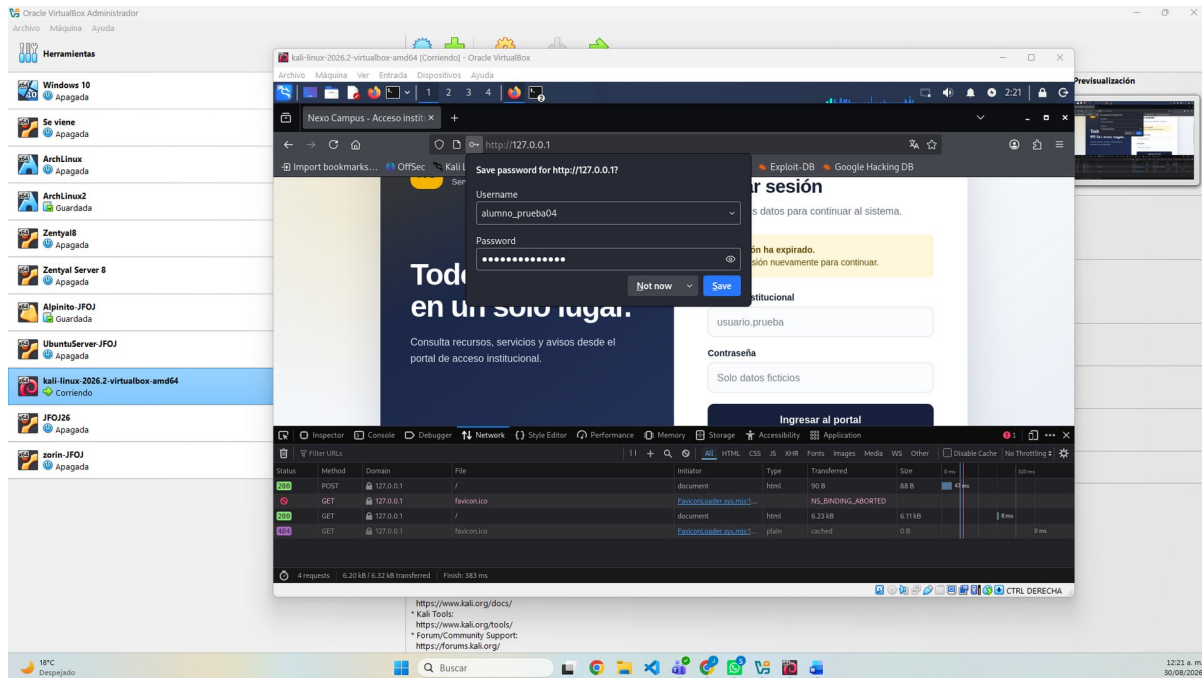


Figura 17. Envío de datos ficticios y petición POST con respuesta 200. Después de presionar el botón, el monitor registró POST / hacia 127.0.0.1 con estado 200. El aviso de Firefox para guardar la contraseña corresponde al navegador y no forma parte de SET.

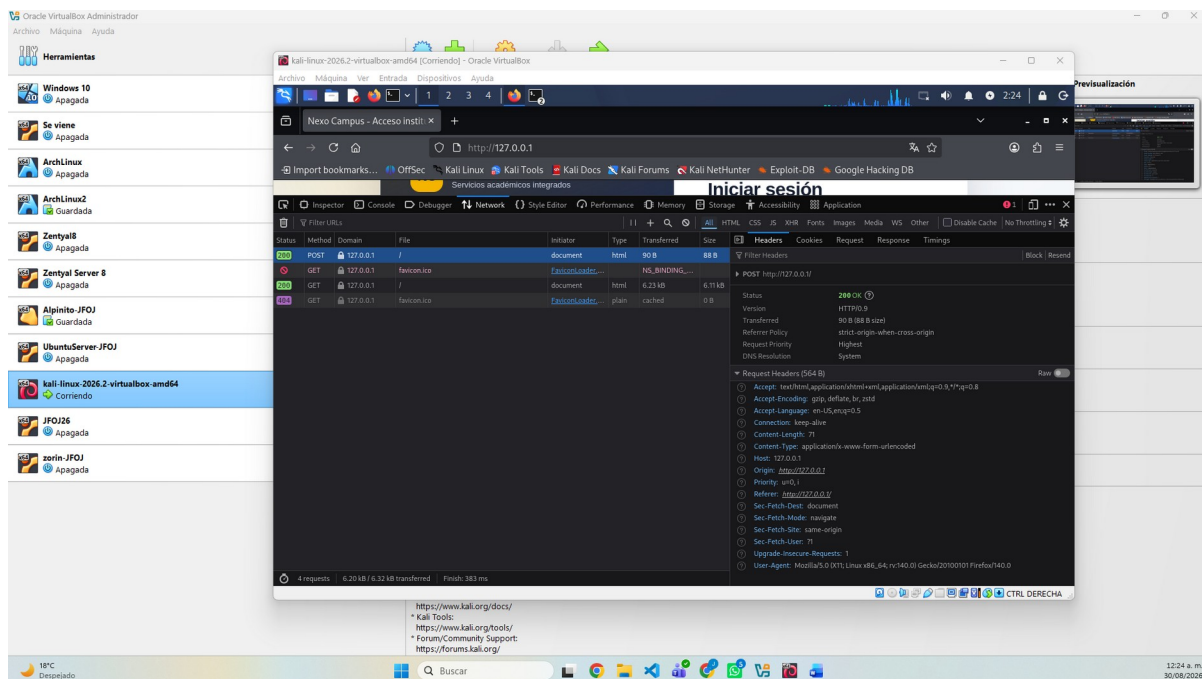


Figura 18. Encabezados de la petición HTTP. La vista Headers confirma método POST, destino http://127.0.0.1/, estado 200 OK y Content-Type application/x-www-form-urlencoded, formato usado para serializar los campos del formulario.

BITÁCORA VISUAL · CAPTURA Y ANÁLISIS TÉCNICO

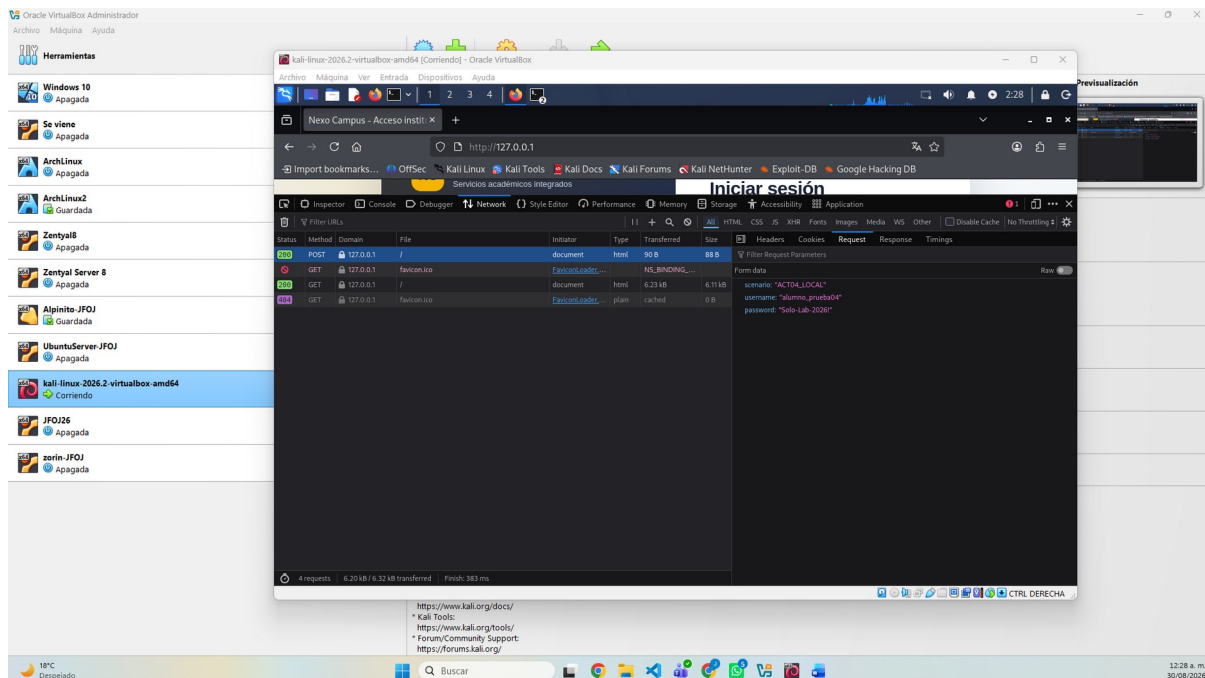


Figura 19. Parámetros enviados por el formulario. La pestaña Request muestra `scenario=ACT04_LOCAL`, `username=alumno_prueba04` y `password=Solo-Lab-2026!`. Todos son datos ficticios creados exclusivamente para esta práctica.

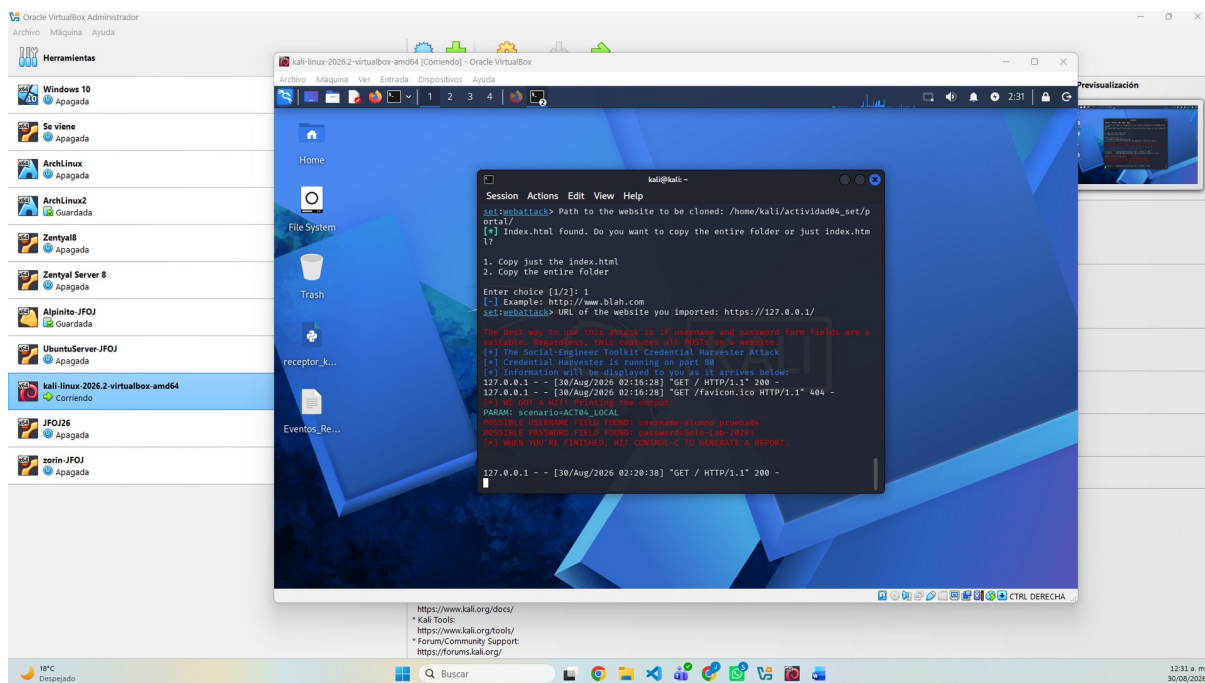


Figura 20. Recepción de parámetros en SET. La consola presentó WE GOT A HIT e identificó los posibles campos de usuario y contraseña. Esto demuestra captura de valores enviados, no descifrado ni recuperación criptográfica.

BITÁCORA VISUAL · CAPTURA Y ANÁLISIS TÉCNICO · CIERRE Y PRESERVACIÓN DE EVIDENCIA

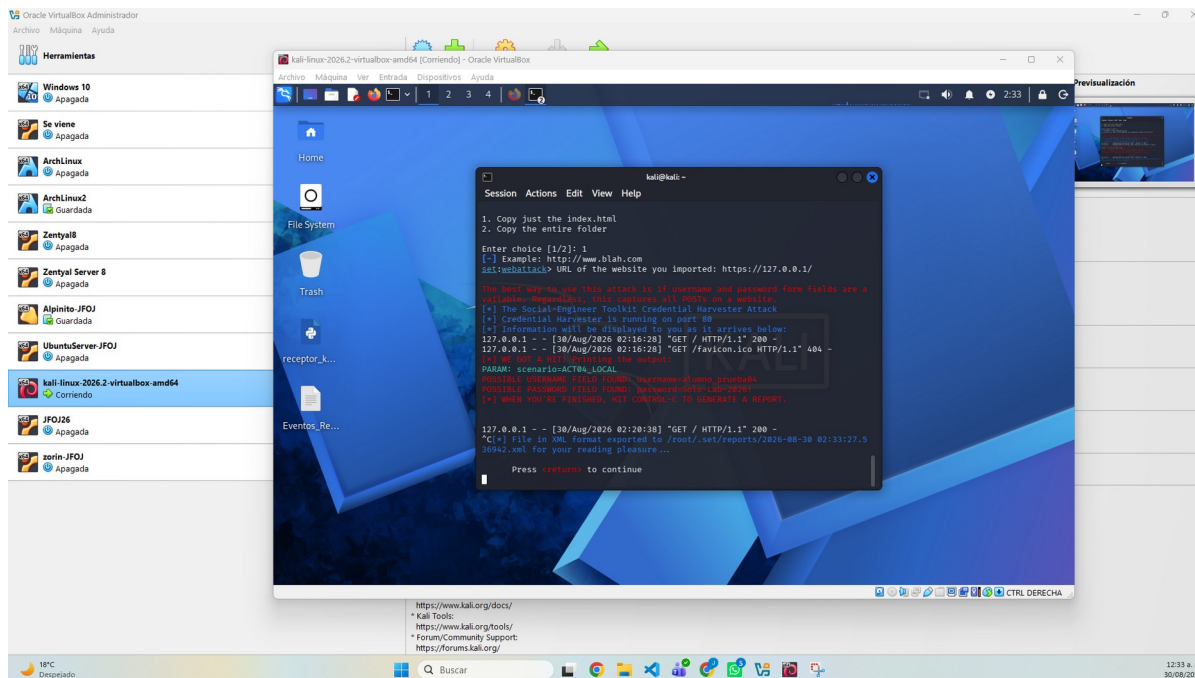


Figura 21. Finalización controlada y generación del reporte XML. Al presionar Ctrl+C, SET informó la creación de un archivo XML en /root/.set/reports/. El reporte conserva los parámetros después de detener el servidor.

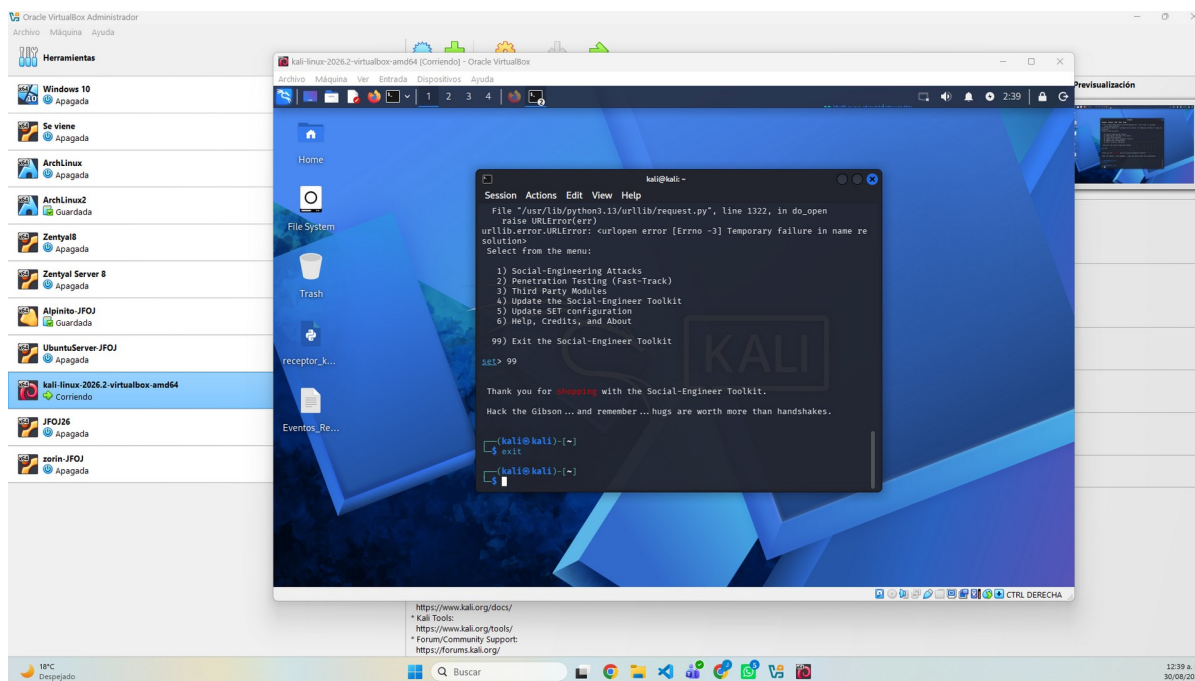


Figura 22. Salida del módulo y de SET. Se regresó al menú principal y se eligió 99 para salir. La sesión terminó sin publicar el servicio ni emplear dominios externos.

BITÁCORA VISUAL · CIERRE Y PRESERVACIÓN DE EVIDENCIA

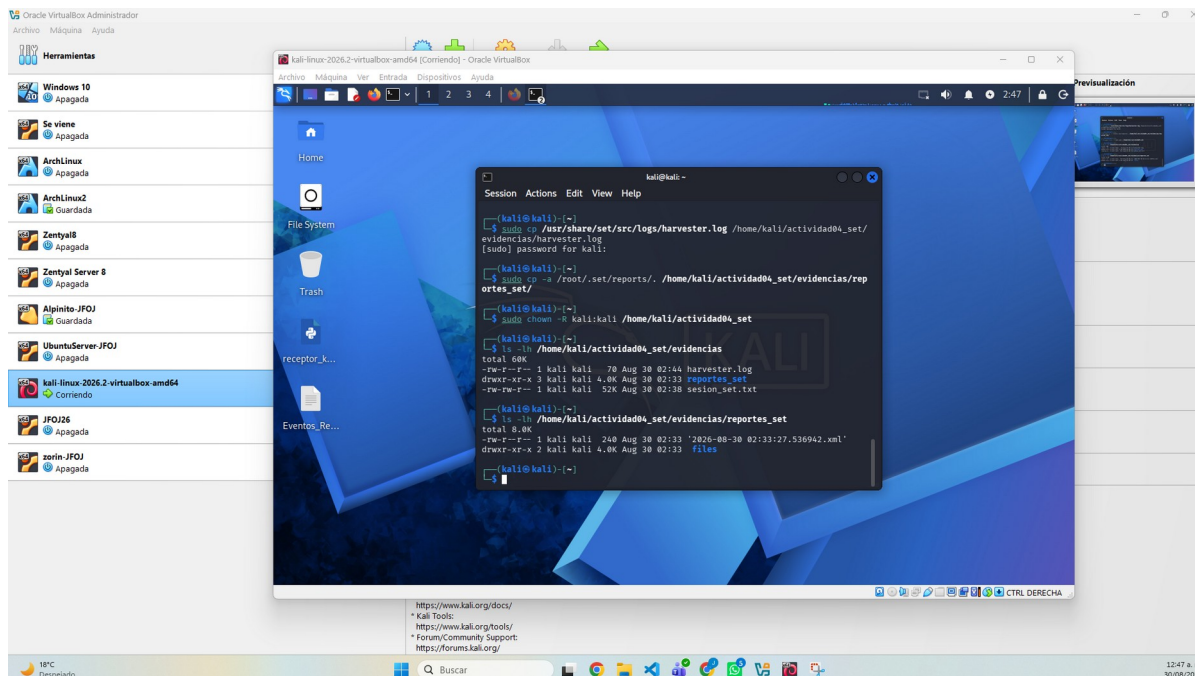


Figura 23. Copia y listado de artefactos de evidencia. harvester.log, session_set.txt y el directorio reportes_set quedaron bajo /home/kali/actividad04_set/evidencias/ con propietario kali, facilitando su conservación y revisión posterior.

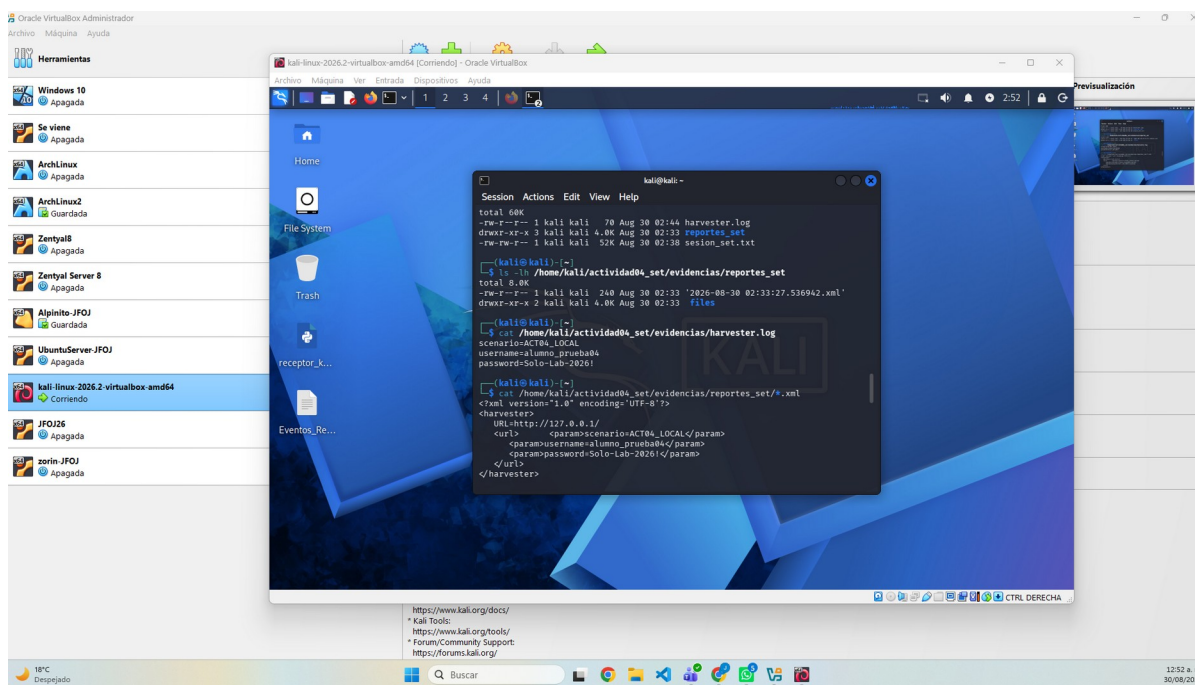


Figura 24. Comprobación de persistencia en el log y en XML. La lectura posterior muestra los mismos valores ficticios en harvester.log y en el XML. La información se mantuvo después de finalizar SET, satisfaciendo el criterio de persistencia local.

BITÁCORA VISUAL · INCIDENCIAS RESUELTAS · CIERRE Y PRESERVACIÓN DE EVIDENCIA

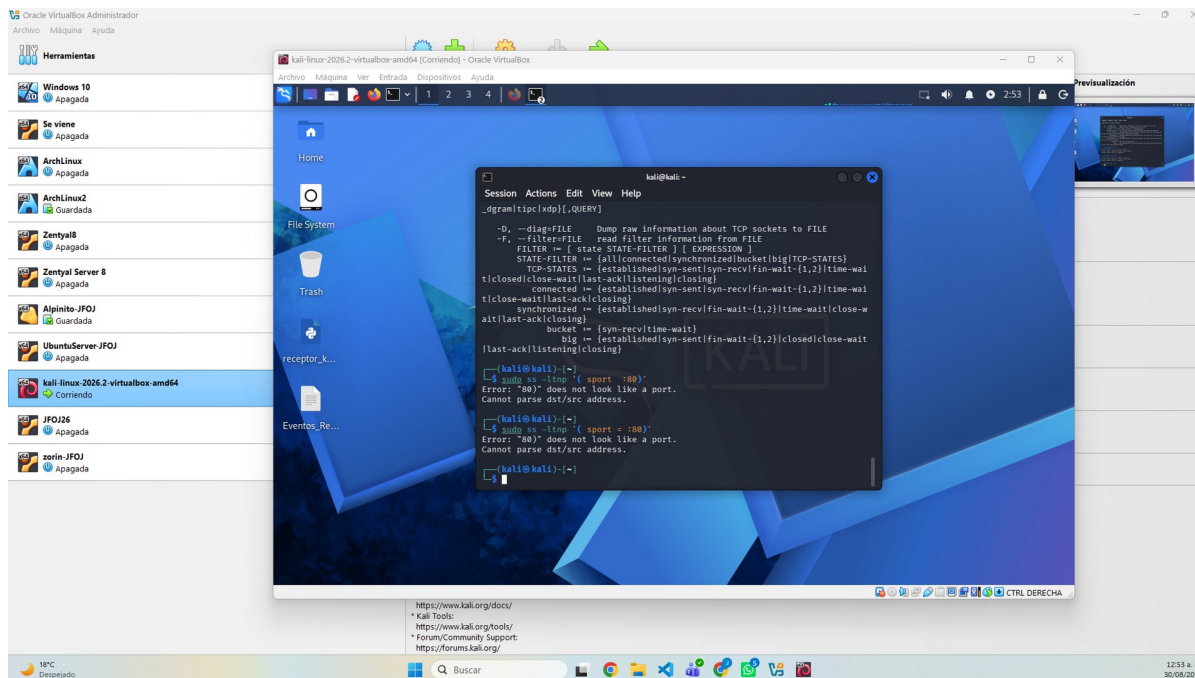


Figura 25. Primeros intentos de filtrado del puerto 80. La sintaxis con sustitución de comandos produjo errores de análisis. La incidencia se documentó y se reemplazó por el filtro nativo sport = :80.

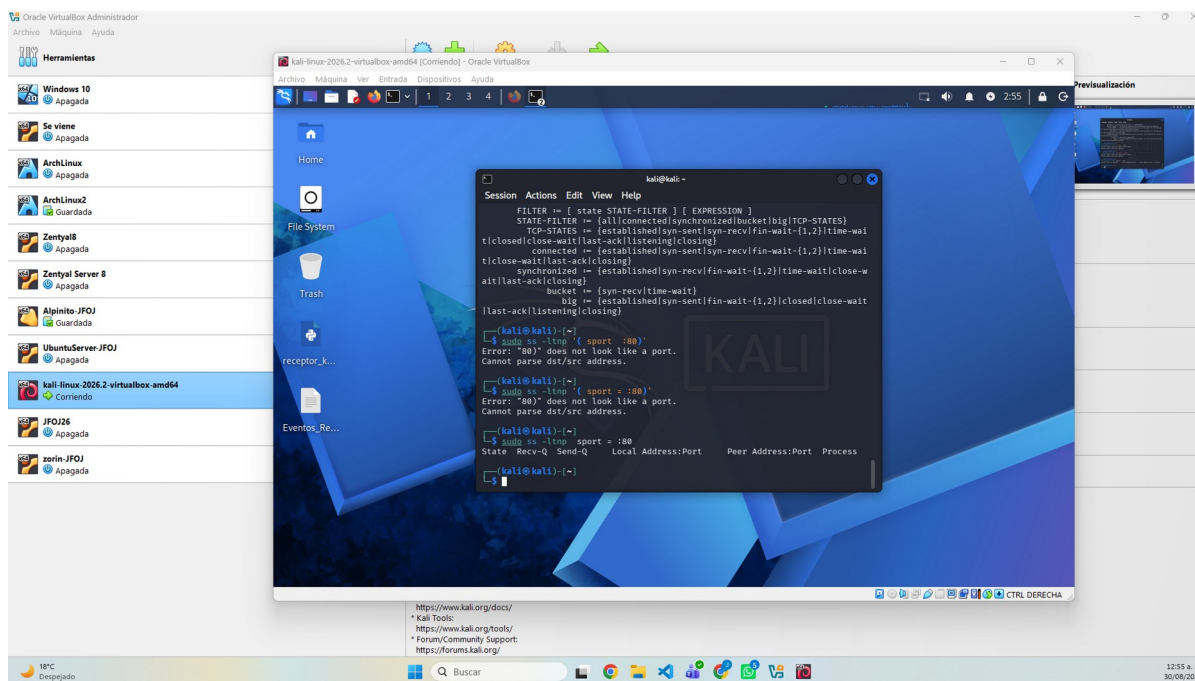


Figura 26. Corrección del comando de comprobación del puerto. El comando `sudo ss -ltnp sport = :80` se ejecutó correctamente. Solo apareció el encabezado, sin sockets, indicando que ya no existía un proceso escuchando en el puerto 80.

BITÁCORA VISUAL · CIERRE Y PRESERVACIÓN DE EVIDENCIA

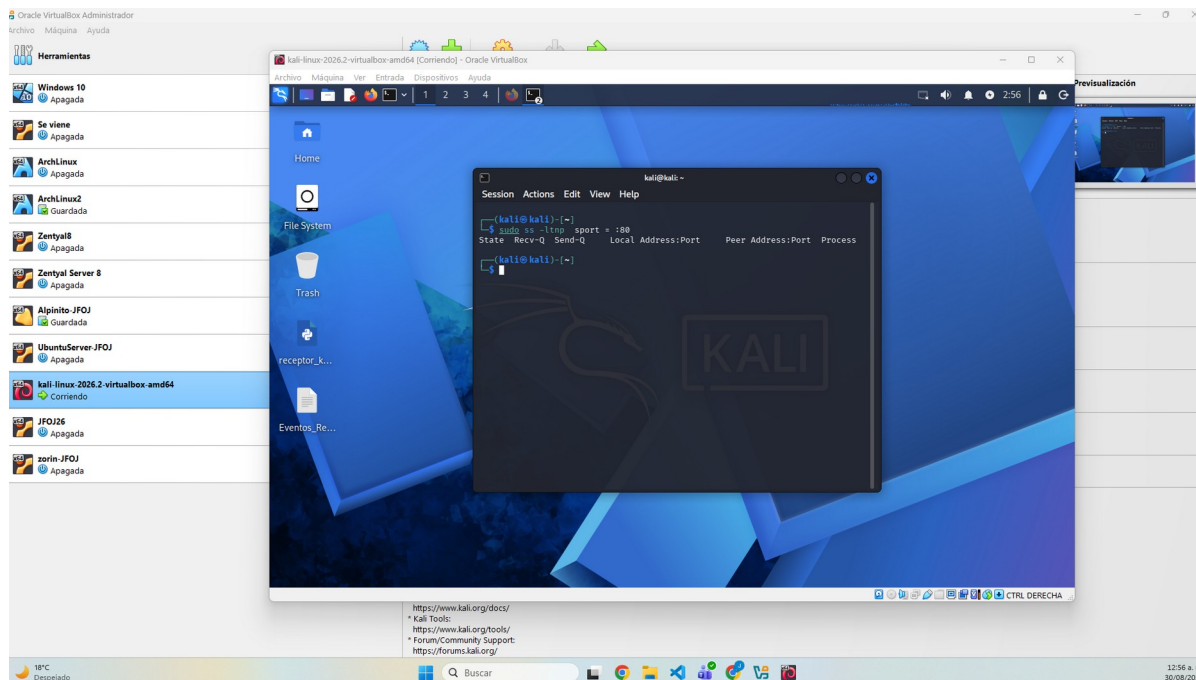


Figura 27. Verificación limpia del servidor detenido. Una segunda ejecución limpia volvió a mostrar únicamente los encabezados de ss. Esta captura confirma que el servicio fue cerrado y no quedó expuesto tras el laboratorio.

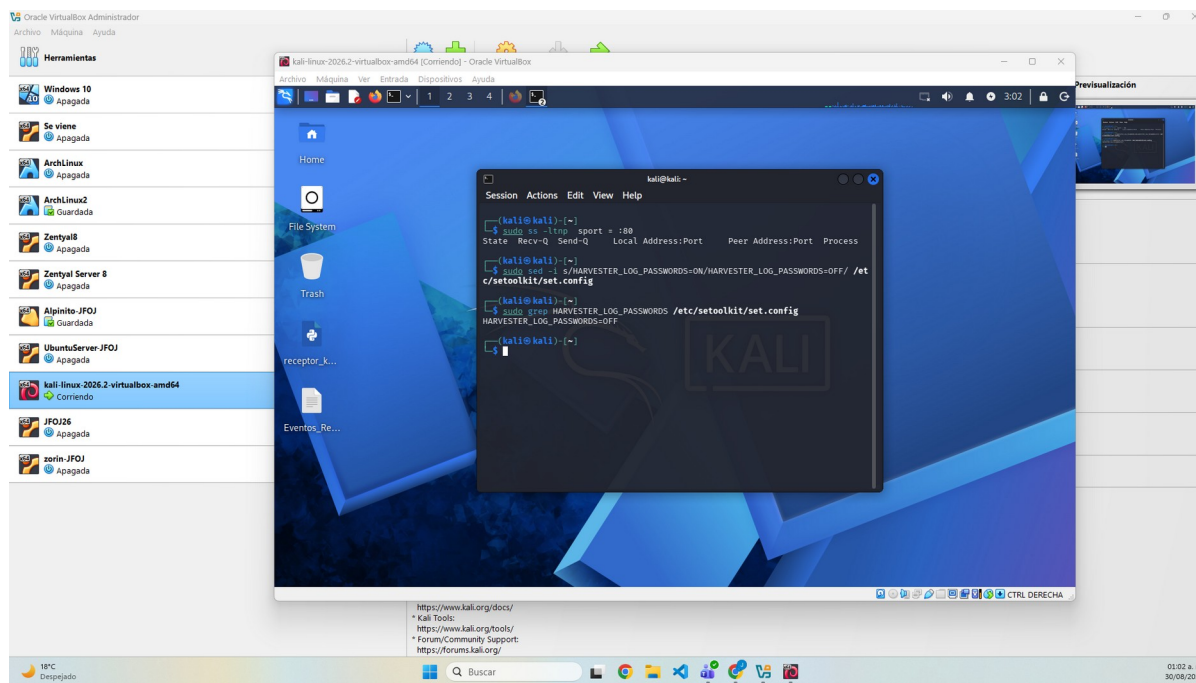


Figura 28. Restauración de la configuración segura. Además de comprobar el puerto cerrado, se cambió HARVESTER_LOG_PASSWORDS de ON a OFF y grep confirmó el estado final. Así se limitó el registro de contraseñas fuera de la ventana autorizada de prueba.

6. Flujo de captura de información



Figura 29. Flujo técnico desde el formulario ficticio hasta la evidencia local y el cierre seguro. Elaboración propia.

6.1 Recorrido de los datos

1. Firefox presenta index.html desde http://127.0.0.1/. El usuario de laboratorio introduce escenario, username y password.
2. Al presionar Ingresar al portal, el navegador serializa los campos con application/x-www-form-urlencoded y crea POST /.
3. La pila TCP/IP dirige la solicitud a la interfaz de loopback. No sale de la máquina virtual ni requiere Internet.

4. El servidor integrado de SET escucha en el puerto 80, recibe el cuerpo de la petición y separa cada par nombre=valor.
5. SET identifica posibles campos de usuario y contraseña y muestra WE GOT A HIT en la consola.
6. Con el registro habilitado para la práctica, los mismos parámetros se conservan en harvester.log y en el reporte XML generado al finalizar.
7. Ctrl+C detiene el servidor. Después se verifica que el puerto 80 no tenga listener y se desactiva el registro de contraseñas.

6.2 Evidencia del POST

Elemento	Valor observado	Interpretación
Método	POST	El navegador envió datos al servidor.
URL	http://127.0.0.1/	La comunicación permaneció en localhost.
Estado	200 OK	SET procesó la solicitud y respondió.
Content-Type	application/x-www-form-urlencoded	Los controles viajaron como pares nombre=valor.
Content-Length	71 bytes	Tamaño del cuerpo mostrado por Firefox.
Parámetros	scenario, username, password	Campos capturados por SET.
Persistencia	Log y XML	La evidencia permaneció después del cierre.

INTERPRETACIÓN El resultado 200 confirma procesamiento, no legitimidad. Una página fraudulenta también puede responder correctamente; la autenticidad depende del origen, el dominio, el certificado, el contexto y los controles de identidad.

07 · DETECCIÓN

7. Indicadores de phishing

CISA recomienda desconfiar de mensajes con lenguaje urgente o emocional y de solicitudes inesperadas de información. En la práctica se reconocieron los siguientes indicadores; ninguno debe evaluarse de forma aislada, porque un solo signo puede aparecer también en un servicio legítimo (CISA, s. f.).

#	Indicador	Por qué es relevante	Alcance y limitación
1	URL inusual o dirección IP directa	Un portal institucional normalmente usa un dominio oficial conocido.	127.0.0.1 es correcto en este laboratorio; fuera de él, una IP o dominio parecido requiere verificación.
2	HTTP sin certificado	La ausencia de HTTPS expone el tráfico y elimina una señal de identidad del servidor.	HTTPS cifra la conexión, pero no prueba por sí solo que el sitio sea legítimo.
3	Mensaje de sesión expirada	Genera urgencia y busca una acción inmediata.	Una sesión real también puede expirar; se debe abrir el portal desde un marcador confiable.
4	Solicitud inesperada de credenciales	Pedir reautenticación desde un enlace recibido es una táctica común.	La solicitud puede ser válida, por lo que debe confirmarse por un canal independiente.
5	Identidad genérica o no reconocida	Nexo Campus no corresponde a un sistema institucional real.	La apariencia profesional puede reducir esta señal; el dominio pesa más que el diseño.
6	Contexto no solicitado	El usuario no inició voluntariamente una gestión de credenciales.	Las notificaciones legítimas existen; conviene entrar manualmente al servicio y revisar avisos.
7	Autorrelleno del gestor ausente o inesperado	Los gestores asocian credenciales al origen y pueden no completar un dominio diferente.	No es una garantía: depende de configuración, coincidencias y hábitos del usuario.

REGLA PRÁCTICA Ante una alerta de sesión o actualización, no usar el enlace recibido. Abrir una ventana nueva, escribir el dominio oficial o usar un marcador verificado, y confirmar el aviso dentro del propio servicio.

08 · PROTECCIÓN EN CAPAS

8. Controles de seguridad propuestos

Un control aislado no elimina el phishing. La reducción del riesgo requiere combinar identidad resistente al phishing, filtrado, diseño seguro, capacitación, monitoreo y respuesta. NIST SP 800-63B-4 define requisitos de autenticación y niveles de garantía; CISA recomienda MFA resistente al phishing cuando sea posible (NIST, 2025; CISA, 2022).

#	Control	Aplicación propuesta	Alcance y limitación
1	MFA resistente al phishing	Usar FIDO2/WebAuthn, passkeys o llaves de seguridad para accesos sensibles.	Evita reutilizar un secreto en un origen falso; requiere compatibilidad, enrolamiento y recuperación segura.
2	DMARC, SPF, DKIM y filtrado	Autenticar el correo y analizar enlaces, remitentes, reputación y adjuntos.	Reduce campañas por correo, pero no cubre SMS, llamadas, cuentas comprometidas ni dominios nuevos.
3	Gestor de contraseñas	Autorrellenar solo en el dominio guardado y generar claves únicas.	Ayuda a detectar orígenes diferentes; no protege si el dominio legítimo está comprometido o el usuario copia la clave.
4	Capacitación y botón de reporte	Realizar simulaciones autorizadas, enseñar indicadores y facilitar el reporte inmediato.	Mejora conducta y visibilidad, pero depende de práctica periódica y no elimina el error humano.
5	Filtrado web y DNS	Bloquear dominios maliciosos, recién creados o categorías de riesgo; aplicar navegación segura.	Puede generar falsos positivos y no detectar infraestructura nueva o comprometida.
6	Acceso condicional y mínimo privilegio	Evaluar dispositivo, ubicación, riesgo de sesión y limitar permisos por función.	Reduce el impacto de una credencial robada; aumenta complejidad y no sustituye la autenticación fuerte.
7	Monitoreo y respuesta	Detectar inicios anómalos, revocar sesiones, restablecer credenciales y preservar evidencia.	Es principalmente detectivo y reactivo: contiene el incidente, pero no impide el primer envío.

8.1 Prioridad recomendada

- Prioridad alta: MFA resistente al phishing, contraseñas únicas y acceso condicional en cuentas críticas.
- Prioridad media: autenticación de correo, filtrado web/DNS, botón de reporte y monitoreo de sesiones.
- Mejora continua: capacitación basada en escenarios, revisión de métricas y ejercicios de respuesta.

09 · EVALUACIÓN

9. Resultados y cumplimiento de la rúbrica

La siguiente matriz relaciona cada criterio con evidencia verificable del informe. La valoración esperada es nivel Excelente en los cinco apartados, sujeto a la revisión del docente.

Criterio	Evidencia incluida	Resultado	Nivel esperado
1. Configuración y ejecución de SET	Figuras 2–4, 10–12, 20–24 y 26–28; log y XML persistentes.	Servidor local funcional, POST recibido, cierre y configuración restaurada.	Excelente · 2 pts
2. Evidencias de la práctica	Figuras 1–28, ordenadas por fase y acompañadas de explicación.	La secuencia permite reconstruir preparación, ejecución, captura y cierre.	Excelente · 2 pts
3. Análisis del funcionamiento	Apartado 6, Figura 29 y comparación captura/cracking.	Se identifica formulario, POST, servidor, parámetros y registros.	Excelente · 2 pts
4. Indicadores y medidas	Siete indicadores y siete controles con alcance y limitaciones.	Supera el mínimo de cinco indicadores y cinco controles justificados.	Excelente · 2 pts
5. Reporte, diagrama y conclusión	Estructura completa, referencias, diagrama y reflexión final.	Contenido coherente con la consigna y los riesgos de ingeniería social.	Excelente · 2 pts

9.1 Resultados verificables

- El portal ficticio abrió correctamente en <http://127.0.0.1/>.
- Firefox registró POST /, 200 OK y los tres parámetros de prueba.
- SET reconoció posibles campos de usuario y contraseña y los mostró en consola.
- harvester.log y el reporte XML conservaron la evidencia después del cierre.
- El servidor quedó detenido y el puerto 80 sin listener.
- HARVESTER_LOG_PASSWORDS se restauró a OFF.
- No se emplearon páginas reales, personas externas, Internet, DNS spoofing, payloads ni código malicioso.

10 · CIERRE

10. Conclusiones

Con esta práctica comprobé que una página de acceso no necesita vulnerar un sistema para provocar una pérdida de información: puede bastar con que una persona confíe en su apariencia y envíe voluntariamente los datos. El punto decisivo fue observar el recorrido completo, desde los campos del formulario hasta el POST, la recepción por SET y la persistencia en los archivos de evidencia.

También comprendí la diferencia entre capturar y crackear una contraseña. SET no rompió un cifrado ni calculó un secreto; recibió el texto ficticio que el navegador transmitió. Por lo tanto, una contraseña compleja sigue siendo vulnerable si se entrega a un origen falso, mientras que controles vinculados al dominio —como FIDO2/WebAuthn y los gestores de contraseñas— pueden reducir ese riesgo.

Las incidencias encontradas fueron útiles para el aprendizaje: localizar la configuración correcta, separar un error de Internet del servicio local, distinguir una ruta de archivos de una dirección IP, alinear HTTP con la configuración SSL y comprobar correctamente el puerto. Documentar cada corrección aporta trazabilidad y demuestra que el resultado no fue accidental.

Finalmente, el ejercicio confirmó que la prevención debe ser por capas. La capacitación ayuda a reconocer señales, pero necesita apoyarse en autenticación resistente al phishing, controles de correo y navegación, acceso condicional, monitoreo y respuesta. Igual de importante es mantener un alcance ético: usar únicamente identidades y datos ficticios, no involucrar terceros, detener el servidor y desactivar el registro al terminar.

APRENDIZAJE CENTRAL La apariencia convence; la evidencia técnica verifica. Antes de entregar una credencial se deben comprobar origen, dominio, contexto y método de autenticación.

11. Referencias

Cybersecurity and Infrastructure Security Agency. (s. f.). Recognize and report phishing. Secure Our World. <https://www.cisa.gov/secure-our-world/recognize-and-report-phishing>

Cybersecurity and Infrastructure Security Agency. (2022). Implementing phishing-resistant MFA [Hoja informativa]. <https://www.cisa.gov/sites/default/files/publications/fact-sheet-implementing-phishing-resistant-mfa-508c.pdf>

Kali Linux. (2026). set: Social-Engineer Toolkit. Kali Linux Tools. <https://www.kali.org/tools/set/>

López Contreras, S. (2026). CNO IV (T37A): Seguridad informática [Presentación de PowerPoint]. Universidad Politécnica de San Luis Potosí.

National Institute of Standards and Technology. (2025). Digital identity guidelines: Authentication and authenticator management (NIST SP 800-63B-4). <https://doi.org/10.6028/NIST.SP.800-63b-4>

TrustedSec. (2026). The Social-Engineer Toolkit (SET) [Código fuente]. GitHub. <https://github.com/trustedsec/social-engineer-toolkit>

CONSULTA Fuentes web verificadas el 30 de agosto de 2026. La consigna y la rúbrica proceden de la presentación proporcionada por el docente.

APÉNDICE · DOCUMENTOS DE REFERENCIA

Apéndice A. Consigna y rúbrica

Se incorporan las dos capturas de referencia entregadas para la actividad. Su inclusión facilita comprobar que la estructura del reporte, el alcance ético y la matriz de evaluación se atendieron de forma explícita.

BITÁCORA VISUAL · DOCUMENTO DE REFERENCIA

ACTIVIDAD 04 -
Una página demasiado convincente

Objetivo general

Implementar y analizar, en un entorno de laboratorio controlado, una simulación de ingeniería social mediante **Social-Engineer Toolkit (SET)**, utilizando una página web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Objetivos específicos

Al finalizar la actividad, el alumno deberá ser capaz de:

- Configurar un escenario básico de ingeniería social utilizando **Social-Engineer Toolkit (SET)**.
- Implementar una página web ficticia mediante el módulo **Credential Harvester**.
- Analizar el proceso mediante el cual la información introducida en un formulario web es transmitida y registrada por un servidor.
- Identificar indicadores técnicos y visuales que permitan reconocer una página potencialmente fraudulenta.
- Proponer controles de seguridad orientados a prevenir o reducir el impacto de ataques de phishing.

Duración aproximada:

02 horas y 30 minutos.

Escenario

El área de seguridad informática de una organización ha recibido varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales. El mensaje contiene un enlace que dirige a un portal aparentemente institucional. La página incluye logotipo, campos de usuario y contraseña y un mensaje indicando: "Su sesión ha expirado. Inicie sesión nuevamente para continuar." A primera vista, nada parece fuera de lo común. Sin embargo, el portal **no pertenece a la organización**.

Inicia Social-Engineer Toolkit desde Kali Linux, localiza el módulo: **Credential Harvester Attack Method**.

Agrega capturas al informe y responde.

¿Qué es un Credential Harvester y cuál es su función dentro de una campaña de phishing?

Prepara el escenario, para esta actividad se utilizará una página web diseñada específicamente para el laboratorio.

El portal simulará un sistema institucional de autenticación con los siguientes elementos: nombre del sistema, campo de usuario, campo de contraseña, botón de ingreso, mensaje relacionado con la expiración de una sesión.

Después de cargar tu página al módulo de Credential Harvester, abre el navegador en el servidor local y simula el ataque de ingeniería social.

Entrega tu informe, deberá incluir:

1. Portada.
2. Tabla de índice.
3. Objetivo de la actividad.
4. Descripción del escenario.
5. Configuración del laboratorio.
6. Evidencias y descripción del funcionamiento.
7. Explicación del flujo de captura de información.
8. Controles de seguridad propuestos.
9. Conclusión.
10. Referencias.

Durante esta actividad queda prohibido:

- Utilizar páginas pertenecientes a servicios reales.
- Clonar portales de instituciones o empresas.
- Utilizar credenciales personales.
- Solicitar datos a personas ajenas al laboratorio.
- Publicar el servidor hacia Internet.
- Utilizar dominios externos.
- Implementar técnicas de suplantación DNS.
- Instalar payloads.
- Ejecutar código malicioso.

Figura 30. Consigna oficial de la Actividad 04. La consigna define objetivos, escenario, elementos del portal, contenido obligatorio del informe y prohibiciones del laboratorio.

ACTIVIDAD 04 -
Una página demasiado convincente

Criterio	Excelente - 2 pts	Bueno - 1 pt	Suficiente - 1 pt	Insuficiente - 0 pts
1. Configuración y ejecución de SET	El programa registra correctamente los eventos en un archivo local y conserva la información después de finalizar la ejecución.	Ejecuta correctamente la simulación, aunque presenta errores menores de configuración que no afectan el resultado final.	Logra ejecutar parcialmente la práctica o requiere correcciones importantes para que SET funcione correctamente.	No logra configurar o ejecutar la simulación solicitada.
2. Evidencias de la práctica	Presenta las evidencias completas, claras, ordenadas y suficientes para comprobar cada etapa realizada.	Presenta la mayoría de las evidencias y permiten comprobar el desarrollo de la práctica, aunque alguna es incompleta o poco clara.	Presenta evidencias parciales que únicamente permiten comprobar algunas etapas de la práctica.	No presenta evidencias suficientes para comprobar la realización de la actividad.
3. Análisis del funcionamiento del ataque	Explica correctamente el recorrido de la información desde el formulario hasta SET, identificando la petición HTTP, el servidor y el registro de parámetros, y distingue claramente entre captura de credenciales y vulneración de una contraseña.	Explica correctamente el funcionamiento general de la simulación, aunque omite o desarrolla superficialmente alguno de los elementos técnicos.	Describe de manera general lo ocurrido, pero presenta confusiones sobre el funcionamiento técnico o el papel desempeñado por SET.	No explica el funcionamiento de la simulación o presenta una interpretación técnica incorrecta.
4. Identificación de indicadores y medidas de protección	Identifica al menos cinco indicadores relevantes de phishing y propone cinco controles de seguridad correctamente justificados, explicando sus alcances y limitaciones.	Identifica los indicadores y controles solicitados, aunque algunas justificaciones son poco desarrolladas o presentan pequeñas imprecisiones.	Identifica parcialmente los indicadores o controles solicitados y ofrece explicaciones generales con poca justificación.	No identifica adecuadamente los indicadores de phishing ni propone controles pertinentes.
5. Reporte, diagrama y conclusión	Entrega un reporte completo, organizado y técnicamente coherente; el diagrama representa correctamente el flujo de la simulación y la conclusión demuestra comprensión de los riesgos de ingeniería social.	El reporte cumple con la estructura solicitada y presenta un análisis adecuado, aunque existen omisiones menores en el diagrama, organización o conclusión.	El reporte cumple con la estructura solicitada y presenta un análisis adecuado, aunque existen omisiones menores en el diagrama, organización o conclusión.	El reporte está incompleto, carece del diagrama solicitado o no presenta una conclusión relacionada con los aprendizajes de la actividad.

Figura 31. Rúbrica de evaluación. La rúbrica valora configuración y ejecución, calidad de evidencias, análisis técnico, indicadores y controles, así como reporte, diagrama y conclusión.